

Our ref.: 11.17.001.009.287

November 26, 2024

Decision

Complaint against CMC Certus Management Consultants Ltd for unlawful transfer and breach of personal data

With regard to the complaint submitted to my Office on XXXX, by Mr. XXXX and Mrs. XXXX, hereafter “the Complainants”, through their lawyers, against CMC Certus Management Consultants Ltd, hereafter “the controller” or “the company”, through its Director, Mr. XXXX, hereafter “the Director”, in accordance with Articles 57(1)(f) and 77 of the Regulation (EU) 2016/679, hereafter the General Data Protection Regulation, “the GDPR”, I issue the following Decision:

1. Facts of the case

The complaint

1.1. On 15/02/2021, the Complainants entered into a contract with the company, according to which the latter should provide various services for the Complainants for obtaining residence permit in Cyprus.

1.2. According to the Complainants, in the context of the contract, they gave to the Director, among other things, bank account statements, their marriage certificate and payroll statements with aim to be translated, from German to Greek.

1.3. At the end of March, beginning of April 2021, the Complainants claimed they contacted the Director and requested to give them back the documents they had given him and the translated copies. They also claimed he informed them that the documents had been sent to Georgia where the company also maintains offices. The Complainants added they had not been informed about this transfer and never consented to it.

1.4. On 16/09/2021, the Complainants were informed that their marriage certificate and Mrs. XXXX payroll statement were posted on the online platform "Scribd" by a user named “XXXX”, thus being accessible to all users of this platform. The documents contained the following personal data: full names of

the Complainants, date and place of marriage, date and place of birth, address, social security number, tax identification number, salary amount for January, date of employment start and the name of the company with which Mrs XXXX was insured. The same day, the Complainants contacted the platform and requested the removal of their documents. The documents were removed the following day.

1.5. After investigating the incident, the Complainants found out that, the user named "XXXX" who had uploaded their documents on the platform, could be a translator employed by CMC LLC, a company based in Georgia.

1.6. On 16/09/2021, the Complainants informed the Director of the controller about the exposure of their personal data on the online platform "Scribd" and requested the deletion of all their documents and personal data. They also requested to be informed, to whom these documents sent to. On 18/09/2021, the Director replied that the company does not use this platform.

1.7. On 20/09/2021, the Complainants sent an email to the Director of the controller and attached screenshots, documenting the exposure of their personal data on the platform. On the same day, the Director replied that the incident would be investigated and he would reply to them as soon as possible. Since then, the Complainants did not receive any feedback on this matter.

Correspondence with the Director of the controller

1.8. In the course of the investigation, on 08/04/2022, I informed the Director of the controller about the complaint and requested his positions. Subsequently, my Office had extensive email correspondence with him. From his replies dated 11/05/2022, 01/07/2022, 10/05/2023 and 17/07/2023, his positions on the case are summarized as follows:

- (a) The company had entered into an agreement with the Complainants to offer them consultancy and/or immigration services in Cyprus in order to obtain a residence permit in Cyprus.
- (b) The company requested the Complainants' bank statements, marriage certificate and payroll statements because, these documents are required when submitting residency applications at the Immigration Office, according to Alien and Immigration Regulations.
- (c) The said documents were maintained and/or stored in the Director's email account to be used for the residency application and they would be deleted after the submission of the application.
- (d) The documents were translated by a team member of the company's office in Larnaca because, according to Alien and Immigration Regulations, it was not necessary to officially translate them for the residency application. If the Authorities in Larnaca had requested official translations, this would be done by a sworn translator.

- (e) When the Complainants informed the Director that their documents were exposed on the platform “Scribd”, he replied that his company does not use this platform, he did not know who uploaded their documents and that he examined the matter and did not find any breach of his email account.
- (f) When the Complainants requested the deletion of their documents, the Director immediately complied and deleted them from his email account.
- (g) The Director maintained that the documents’ leakage did not occur from the company’s side and that he could only assume, they leaked during their transmission from the Complainants to him.
- (h) The only nexus between the company and Certus Management Services LLC, which is based in the Republic of Georgia, is that both companies are controlled by the Director. The two companies do not have any connected business activities. The Cypriot company deals with business consultancy and assists clients to reside in Cyprus. Certus Management Services LLC mainly deals with clients’ relocation to Georgia.
- (i) Regarding the Complainants’ allegation that he informed them that the documents had been sent to Georgia for translation, the Director claimed that he probably mentioned Georgia in another context.
- (j) The Director claimed that “XXXX” is a very common name in Georgia and that he can only assume that it is a coincidence. He added that he did not know the platform “Scribd” and that, his team members in Cyprus do not use it either.
- (k) The Complainants’ documents were translated by a team member of the company, at its office in Larnaca.

1.9. In the light of the above, I could not safely conclude that the Complainants' personal data were breached by the Controller, despite of all the coincidences, surrounding the case. Therefore, on 19/08/2022, we informed the Director that the investigation did not produce any evidence supporting a data breach by the company. However, I cited the following coincidences:

- (a) the company in Larnaca and Certus Management Services LLC in the Republic of Georgia are controlled by the same person, i.e. the Director.
- (b) Certus Management Services LLC employees a translator named Mr. XXXX and the documents in question were uploaded on the platform “Scribd” by a user named “XXXX”.

1.10. In the same letter, I informed the Director that in lack of supporting evidence, the investigation was terminated and on 14/09/2022, I informed the Complainants that in the light of all documentation brought before us, I could not proceed to further investigation of the complaint.

Additional evidence

1.11. On 14/02/2023, the Complainants sent us the following invoices, emails and messages for proving that their documents were translated in Georgia, not in Cyprus:

(a) Invoice issued on 19/02/2021, by Certus Management Services LLC, based in Georgia.

(b) Invoice issued on 24/02/2021, by Certus Management Services LLC, based in Georgia.

(c) Email sent by the Director to Mr. XXXX on 19/02/2021, attaching the invoice referred to point (a) above.

(d) Email sent by the Director to Mr. XXXX on 24/02/2021, attaching the invoice referred to point (b) above.

(e) Mr. XXXX bank statement showing his payment made to Certus Management Services LLC, in Georgia, for the invoices referred to in points (a) and (b) above.

(f) Messages exchanged in WhatsApp between 29/03/2021 and 19/04/2021, by the Director and Mr. XXXX, showing the later inquiring the whereabouts of their documents and the Director replying that he was expecting them to arrive via a courier.

(g) Email sent by the Director to Mr. XXXX on 29/03/2021, whereby XXXX mentioning that he would delete all the Complainants' personal data.

1.12. All of the above were accompanied by translations from German to English, done by a sworn translator.

Re-opening of the complaint

1.13. In the light of the above, my Office re-opened the case and on 09/05/2023, I requested the Director's positions with regard to the new evidence submitted by the Complainants. On 10/05/2023, the Director of the controller replied that he could not explain what happened because in conformity with the Complainants' request, he had deleted all their personal data and he does not have any recollection of the case.

1.14. To refresh his recollection of the case, on 16/05/2023 and 29/05/2023, I sent to the Director all the documents mentioned in paragraph 1.11. above and all the correspondence he had exchanged with my Office, since 08/04/2022, respectively. On 17/07/2023, the Director replied that, again, he could not give any explanations, since he had deleted all his relevant communications with the Complainants.

1.15. It should be noted that on 08/04/2022, before re-opening the case, I asked the Director for the provisions of Chapter V he had relied upon, for transferring the said documents to a third country, e.g. the Republic of Georgia. In his reply, he maintained that no such transfer occurred. He maintained the same position after the re-opening of the case.

Preliminary decision

1.16. On 25/07/2024, I issued a preliminary decision, concluding a prima facie, that the transfer of the said documents, from the company in Cyprus, to the company in the Republic of Georgia, was in violation of Chapter V of the GDPR.

1.17. Also, I concluded a prima facie, that the controller did not take appropriate technical or organisational measures, for preventing the accidental leakage of the said documents and their exposure on the platform Scribd, in violation of Article 5(1)(f) of the GDPR.

1.18. In addition, I concluded that the controller's failure to provide my Office with adequate explanations about the facts of the case, a prima facie, constituted a violation of Article 31 of the GDPR.

1.19. In the context of the right to be heard enshrined in section 43 of Law 158(I)/1999, I called the controller to submit to my Office, until 25/08/2024, his views on (a) the facts of the case, (b) the prima facie violations of the GDPR cited above, (c) the reasons why I should not impose any sanctions to the company, and/ or any mitigating factors that I should take into account, before I deliver my final Decision.

1.20. On 04/09/2024, the controller replied that, he reviewed the documents very carefully, he had never used Scribed and he first heard about it, in the context of this case. Also, since he had deleted all documents and communications with the complainant, as it was demanded of him, he had difficulty to review the case from his side. In addition, the controller informed me that they hired a person to deal with compliance and data protection in order to make sure that they will be always comply with the existing data protection regulations.

2. Legal framework

2.1. Article 4 of The General Data Protection Regulation, hereafter the "GDPR", provides the following definitions:

(1) 'personal data' means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;

(2) ‘processing’ means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;

(7) ‘controller’ means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;

(12) ‘personal data breach’ means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed;

2.2. The Principle of Integrity and Confidentiality enshrined in GDPR Article 5(1)(f) provides that personal data shall be *“processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures”*.

2.3. The Principle of Accountability set out in GDPR Article 5(2) provides that *“The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1.”*.

2.4. Article 31 of the GDPR provides that *“The controller and the processor and, where applicable, their representatives, shall cooperate, on request, with the supervisory authority in the performance of its tasks.”*.

2.5. CHAPTER V of the GDPR sets out the conditions for transfers of personal data to third countries or international organisations. In particular, Article 44 lays down the general principle for transfers, Article 45 regulates transfers on the basis of an adequacy decision, Article 46 provides for transfers subject to appropriate safeguards, including standard contractual clauses, Article 47 enables transfers on the basis binding corporate rules, Article 48 regulates transfers or disclosures not authorised by Union law, Article 49 provides for derogations for specific situations and Article 50 for International cooperation for the protection of personal data.

2.6. Article 44 of the GDPR provides that *“Any transfer of personal data which are undergoing processing or are intended for processing after transfer to a third country or to an international organisation shall take place only if, subject to the other provisions of this Regulation, the conditions laid down in this Chapter are complied with by the controller and processor, including for onward transfers of personal data from the third country or an international organisation to another third country or to another international organisation. All provisions in this Chapter shall be applied in order to ensure that the level of protection of natural persons guaranteed by this Regulation is not undermined.”*.

2.7. Article 58(2) of the GDPR vests to the Commissioner corrective powers, which include the following:

(a) to issue warnings to a controller or processor that intended processing operations are likely to infringe provisions of this Regulation;

(b) to issue reprimands to a controller or a processor where processing operations have infringed provisions of this Regulation;

(i) to impose an administrative fine pursuant to Article 83, in addition to, or instead of measures referred to in this paragraph, depending on the circumstances of each individual case;

(j) to order the suspension of data flows to a recipient in a third country or to an international organisation.

2.8. The general conditions for imposing administrative fines are laid down in Article 83.

3. Reasoning

3.1. The core subject matter of the case can be summarized in four questions:

(a) Did the controller transfer the Complainants' documents, from the company in Cyprus, to a company in Georgia, also controlled by its Director?

(b) If yes, was this transfer in line with Chapter V of the GDPR?

(c) Did the controller take appropriate technical or organizational measures to ensure the security of the Complainants' documents, in line with Article 5(1)(f) of the GDPR?

(d) Did the controller cooperate with my Office in line with his obligation stemming from Article 31 of the GDPR?

First question

3.2.1. Based on the evidence brought before me, two invoices were issued for translation fees. Both invoices were issued by Certus Management Services LLC, in Georgia, on 19/02/2021 and on 24/02/2021, respectively. However, the invoices were sent to Mr. XXXX email by the Director in his capacity as the Director of the controller in Cyprus. One invoice was sent on 19/02/2021 and the other, on 24/02/2021. From Mr. XXXX bank statement, it is apparent that the payment for the outstanding invoices was made to Certus Management Services LLC, in Georgia.

3.2.2. Therefore, as regards first question the answer must be that the evidence brought before me, provides sufficient proof that the complainants' documents were transferred, from the controller in Cyprus, to the company in the Republic of Georgia.

Second question

3.3.1. Chapter V of the GDPR demands that transfers of personal data to third countries are subject to the conditions and safeguards set out in this Chapter. Both before and after the re-opening of the case, the Director was asked for the provisions of Chapter V he had relied upon, for transferring the said documents to a third country, e.g. the Republic of Georgia. The Director maintained he had no recollection of the case and could not give any explanation on the matter.

3.3.2. Since it has been established, without any doubt, that the said documents were transferred from the company in Cyprus to the company in the Republic of Georgia and in lack of any explanations provided by the Director, before or after the re-opening of the case, the answer to the second question must be that this transfer took place in violation of Article 44 of Chapter V of the GDPR.

Third question

3.4.1. Article 5(1)(f) of the GDPR obliges controllers, to have mechanisms in place for ensuring the security of personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage.

3.4.2. It has been established that the complainants' documents were uploaded on the platform Scribd, by a user named XXXX. It has also been established that the Director's company in Georgia, employees a person named XXXX. Furthermore, it has been established that the invoices for the translation of the documents were issued by the Georgian company and that the payment for their translation, was made to the Georgian company.

3.4.3. The established findings strongly suggest that the said documents leaked from the Georgian company. However, it cannot be safely dismissed, that the documents leaked from the Cypriot company. The Director's position was that leakage could have taken place during the transmission of the documents, when Mr. XXXX emailed them to him. No evidence was brought before me to support this possibility and the investigation findings, certainly do not advocate in its favour. In the absence of any evidence suggesting otherwise, from the facts of the case it can safely be deducted that the documents leaked, either from the Cypriot company or from the Georgian company.

3.4.4. When the documents were uploaded on Scribd, they were definitely in the possession of the Cypriot company (the controller). I have no reason to dispute that the controller did not intentionally upload the said documents on Scribd. But did the controller prove that they were not uploaded by accident? In line with Article 5(1)(f), the controller ought to have in place a safety mechanism for preventing the accidental leakage of documents, either from the company in Cyprus or from the Georgian company. Moreover, in accordance with the Principle of Accountability, the controller should have been in a position to demonstrate that such a mechanism was indeed in place. This Principle lays the burden of proof onto controllers.

3.4.5. In our extensive correspondence, the controller failed to demonstrate that such a mechanism was in place, for preventing the accidental leakage of the said documents. If such a mechanism was in place, it was not brought to my attention. Therefore, the answer to the third question must be that the controller did not take appropriate technical or organizational measures to ensure the security of the Complainants' documents, in line with Article 5(1)(f).

Fourth question

3.5.1. While the Director of the controller replied to all of my Office's emails in a timely manner, he failed to provide adequate explanations to certain facts for the case. For example, he always maintained that the documents were translated in Cyprus, by a team member of the company's Larnaca office. When asked to provide explanation regarding the transfer of the documents, the Director of the controller responded that he could not provide such explanation, since he had deleted all relevant communications with the Complainants. The Director of the controller maintained this view even when he was presented with the emails, he had sent to Mr. XXXX with the attached invoices issued by the Georgian company and the proof of payment to this company (our email dated 16/05/2023).

3.5.2. The exposure of his clients' documents could have a severe impact both onto his clients and onto the reputation of his companies. Therefore, when he was informed of this exposure, he should have investigated it more thoroughly and he should have been in a position to provide more adequate explanations to my Office, about the facts surrounding this exposure. As a result, the answer to the fourth question must be that, the controller cooperated with my Office, but not to the degree and extend demanded of him, by GDPR Article 31.

4. Conclusion

4.1. As regards the second question, taking into account the answer to the first question cited in paragraph 3.2.2, I conclude that the transfer of the documents, from the company in Cyprus, to the company in the Republic of Georgia, was carried out in violation of Article 44 of Chapter V of the GDPR.

4.2. As regards the third question, I conclude that the controller did not take appropriate technical or organisational measures, for preventing the accidental leakage of the said documents and their exposure on the platform Scribd, in violation of Article 5(1)(f) of the GDPR.

4.3. As regards the fourth question, I conclude that the controller failed to cooperate with my Office, to the degree and extend demanded of him, by GDPR Article 31.

Mitigating factors

4.4. In my Preliminary Decision, I asked the controller, in the course of his right to a hearing, to submit to my Office any mitigating factors that should be taken

into account, before I deliver my final Decision. He did submit any but having examined the facts of the case, I considered the following, as mitigating factors:

4.4.1. The Director's timely response to all our emails.

4.4.2. The incident in question concerned only two data subjects.

4.4.3. The Complainants' documents were exposed on the platform only for a short period of time.

4.4.4. The Director deleted the Complainants' data when asked to do so.

4.4.5. There was no previous complaint against the controller.

4.4.6. No sensitive data have been affected.

4.4.7. The controller employed a person to deal with compliance with existing data protection rules.

Aggravating factors

4.5. The circumstances of the cases demand that the following aggravating factors are taken into consideration:

4.5.1. The Director maintained the view that the documents in question were not transferred to his company in the Republic of Georgia, even after it became evident that they had been transferred.

4.5.2. As explained in paragraph 3.5.2. in the course of the investigation, the Director cooperated with my Office, but not to the degree and extend demanded of him, by GDPR Article 31, since he did not provide more adequate explanations to my Office, about the facts surrounding this exposure.

Corrective measures

4.6. In view of the above, by virtue of the powers conferred on me by GDPR Article 58(2)(i) and in accordance with Article 83:

4.6.1. For the transfer of the complainants' document, from CMC Certus Management Consultants Ltd in Larnaca, to Certus Management Services LLC in the Republic of Georgia, in violation of Article 44 of Chapter V of the GDPR, I impose to CMC Certus Management Consultants Ltd (the controller) an administrative fine of 2000 euro.

4.6.2. For the absence of appropriate technical or organisational measures, for preventing the accidental leakage of the said documents and their exposure on the platform Scribd, in violation of Article 5(1)(f) of the GDPR, I impose to CMC Certus Management Consultants Ltd (the controller) an administrative fine of 2000 euro.

4.7. By virtue of the power conferred on me by GDPR Article 58(2)(b), for not cooperating with my Office, to the degree and extend demanded by GDPR Article 31, I issue a Reprimand to CMC Certus Management Consultants Ltd (the controller).

Irene Loizidou Nicolaidou
Commissioner
For Personal Data Protection